

NDPR/NDPA COMPLIANCE FRAMEWORK

Marketing4Effect (M4E) — Data Protection Compliance Framework

Applicable Platform: M4E Customer Reactivation Manager (crm.marketing4effect.com)

Effective Date: 1 June 2025

Last Updated: June 2025

Document Version: 1.0

Document ID: M4E-NDPR-CF-2025-001

TABLE OF CONTENTS

1. Executive Summary
 2. Regulatory Overview
 3. Compliance Obligations by Role
 4. Lawful Basis Assessment Framework
 5. Data Protection Impact Assessment (DPIA)
 6. Data Breach Response Procedure
 7. Data Subject Request Handling Procedures
 8. NITDA/NDPC Registration Requirements
 9. Data Protection Compliance Organisation (DPCO) Requirements
 10. Cross-Border Transfer Mechanisms
 11. Annual Audit Requirements
 12. Record-Keeping Obligations
 13. Penalties and Enforcement
 14. Compliance Checklist
 15. References
 16. Document Control
-

1. EXECUTIVE SUMMARY

1.1 Purpose

This document establishes the comprehensive data protection compliance framework for Marketing4Effect (M4E) and its Clients in relation to the M4E Customer Reactivation Manager platform. It provides operational guidance for complying with the Nigeria Data Protection Regulation (NDPR) 2019 and the Nigeria Data Protection Act (NDPA) 2023, which together form the primary data protection legal framework in Nigeria.

1.2 Scope

This framework applies to:

- All personal data processed through the M4E Customer Reactivation Manager platform;
- M4E as Data Processor;
- All Clients as Data Controllers;
- All M4E personnel, contractors, and Sub-Processors involved in the processing of personal data;
- All processing activities including collection, storage, segmentation, campaign delivery, analytics, and deletion.

1.3 Regulatory Context

Nigeria's data protection landscape is governed by two primary instruments:

Instrument	Status	Authority	Key Reference
NDPR 2019	In force (subsidiary legislation under NITDA Act)	NITDA / NDPC	Nigeria Data Protection Regulation 2019
NDPA 2023	In force (primary legislation, signed 12 June 2023)	NDPC	Nigeria Data Protection Act 2023

The NDPA 2023 supersedes the NDPR 2019 as the primary data protection legislation in Nigeria. However, regulations and guidelines issued under the NDPR remain in force to the extent they are not inconsistent with the NDPA. This framework addresses compliance with both instruments.

1.4 Key Compliance Principles

Both the NDPR and NDPA are founded on the following core data protection principles, which M4E and its Clients must observe:

1. **Lawfulness, Fairness, and Transparency** — Personal data must be processed lawfully, fairly, and in a transparent manner (NDPA s.24(1)(a)).
 2. **Purpose Limitation** — Personal data must be collected for specified, explicit, and legitimate purposes and not further processed in a manner incompatible with those purposes (NDPA s.24(1)(b)).
 3. **Data Minimisation** — Personal data must be adequate, relevant, and limited to what is necessary in relation to the purposes for which it is processed (NDPA s.24(1)(c)).
 4. **Accuracy** — Personal data must be accurate and, where necessary, kept up to date (NDPA s.24(1)(d)).
 5. **Storage Limitation** — Personal data must be kept in a form which permits identification of Data Subjects for no longer than is necessary (NDPA s.24(1)(e)).
 6. **Integrity and Confidentiality** — Personal data must be processed in a manner that ensures appropriate security, including protection against unauthorised or unlawful processing and against accidental loss, destruction, or damage (NDPA s.24(1)(f)).
 7. **Accountability** — The Data Controller shall be responsible for, and be able to demonstrate compliance with, the above principles (NDPA s.24(2)).
-

2. REGULATORY OVERVIEW

2.1 Nigeria Data Protection Regulation (NDPR) 2019

2.1.1 Background and Authority

The NDPR was issued by the National Information Technology Development Agency (NITDA) on 25 January 2019 pursuant to Section 32 of the NITDA Act 2007. It was Nigeria's first comprehensive data protection regulation and established the foundational framework for data protection in the country.

2.1.2 Key Provisions Relevant to M4E

NDPR Provision	Requirement	M4E Relevance
Art. 2.1 — Governing Principles	Data must be collected and processed in accordance with specific, legitimate, and lawful purposes consented to by the Data Subject	All processing through the Platform must have a lawful basis
Art. 2.2 — Lawful Processing	Processing is lawful if the Data Subject has given consent, or processing is necessary for the performance of a contract, compliance with a legal obligation, protection of vital interests, public interest, or legitimate interests	Basis for processing existing customer data under legitimate interest
Art. 2.3 — Consent	Consent must be obtained without fraud, coercion, or undue influence; Data Subject must be informed of their right to withdraw consent	Consent management for new prospects without prior purchase history
Art. 2.5 — Third-Party Data	Where data is obtained from a third party, the Data Controller must ensure the third party obtained consent	Client must ensure lawful collection before sharing with M4E
Art. 2.10 — Data Security	Data Controllers and Processors must implement appropriate technical and organisational measures	M4E's security measures (AES-256, TLS 1.2+, RBAC)
Art. 2.11 — Data Breach Notification	Data Controller must report breaches to NITDA within 72 hours	M4E notifies Client within 72 hours; Client notifies NDPC
Art. 2.12 — Privacy Policy	Every Data Controller must publish a privacy policy	Client must have a privacy policy; M4E publishes Platform privacy policy
Art. 3.1 — Rights of Data Subjects	Data Subjects have rights to information, access, rectification, erasure, restriction, portability, and objection	Procedures in Section 7 of this framework
Art. 4.1 — Data Protection Audit	Data Controllers processing personal data of more than 2,000 Data Subjects in a 12-month period must submit a Data Protection Audit report to NITDA/NDPC within 6 months of the end of each year	Annual audit requirement for M4E and Clients
Art. 4.2 — Soft Audit	Data Controllers processing personal data of fewer than 2,000 Data Subjects must conduct a soft audit and submit a summary report	Applicable to smaller Client databases

2.1.3 NDPR Implementation Framework 2020

The NDPR Implementation Framework (issued November 2020) provides additional guidance on:

- Consent requirements and mechanisms
- Lawful basis for processing
- Data protection officer requirements
- Data breach management procedures
- International data transfer requirements
- Data protection audit procedures

2.2 Nigeria Data Protection Act (NDPA) 2023

2.2.1 Background and Authority

The NDPA was signed into law on 12 June 2023 by President Bola Ahmed Tinubu. It is Nigeria's first primary legislation dedicated to data protection, replacing the NDPR as the principal data protection law. The NDPA establishes the Nigeria Data Protection Commission (NDPC) as an independent regulatory body.

2.2.2 Key Provisions Relevant to M4E

NDPA Provision	Requirement	M4E Relevance
s.24 — Principles of Data Processing	Establishes core principles: lawfulness, purpose limitation, data minimisation, accuracy, storage limitation, integrity, accountability	Foundation for all Platform processing activities
s.25 — Lawful Basis for Processing	Six lawful bases: consent, contract performance, legal obligation, vital interests, public interest, legitimate interests	Basis selection for different processing activities
s.26 — Conditions for Consent	Consent must be freely given, specific, informed, and unambiguous; demonstrable by clear affirmative action; withdrawable at any time	Consent management for marketing communications
s.27 — Processing of Sensitive Personal Data	Special categories require explicit consent or other specified conditions	Not typically applicable to M4E (no sensitive data processed)
s.28-33 — Data Controller Obligations	Privacy policy, data protection officer, data processing records, DPIA, prior consultation, data breach notification	Client obligations as Data Controller
s.34-40 — Data Subject Rights	Access, rectification, erasure, restriction, portability, objection, automated decision-making	Rights handling procedures in Section 7
s.41-44 — Data Processor Obligations	Process only on Controller instructions; ensure confidentiality; implement security measures; assist Controller; notify breaches; maintain records	M4E's obligations as Data Processor
s.45-48 — International Data Transfer	Transfer only to jurisdictions with adequate protection or with appropriate safeguards	Cross-border transfer mechanisms in Section 10
s.49-53 — NDPC Establishment and Powers	Establishes NDPC as independent regulator with investigation, enforcement, and penalty powers	Regulatory authority for compliance
s.54-58 — Registration and Licensing	Data Controllers and Processors of major importance must register with NDPC	Registration requirements in Section 8
s.59-65 — Enforcement and Penalties	Administrative fines, compliance orders, criminal penalties for serious offences	Penalties overview in Section 13

2.2.3 Relationship Between NDPR and NDPA

The NDPA 2023 is the superior legislation. Key implications:

1. **NDPA prevails** in case of conflict between NDPR and NDPA provisions.
 2. **NDPR regulations remain valid** to the extent they are consistent with the NDPA and until replaced by NDPC regulations.
 3. **NDPC replaces NITDA** as the primary regulatory authority for data protection.
 4. **Existing NDPR compliance** provides a strong foundation but must be supplemented with NDPA-specific requirements.
-

3. COMPLIANCE OBLIGATIONS BY ROLE

3.1 M4E as Data Processor

M4E, as Data Processor under the Service Agreement, has the following compliance obligations:

3.1.1 Statutory Obligations (NDPA s.41-44)

Obligation	NDPA Reference	Implementation
Process only on documented Controller instructions	s.41(1)(a)	Service Agreement Section 8.2; processing limited to agreed purposes
Ensure confidentiality of processing personnel	s.41(1)(b)	Confidentiality agreements with all personnel; NDA requirements
Implement appropriate security measures	s.41(1)(c)	Technical and organisational measures per Privacy Policy Section 10
Engage Sub-Processors only with Controller authorisation	s.41(1)(d)	Sub-Processor list in Service Agreement Section 8.9; prior notification
Assist Controller with Data Subject rights	s.41(1)(e)	Procedures in Section 7 of this framework
Assist Controller with security, breach notification, DPIA	s.41(1)(f)	Breach procedures in Section 6; DPIA guidance in Section 5
Delete or return data after service ends	s.41(1)(g)	Service Agreement Section 9.3(a) and 8.7
Make compliance information available for audits	s.41(1)(h)	Audit provisions in Section 11
Maintain records of processing activities	s.42	Record-keeping procedures in Section 12
Notify Controller of breaches without undue delay	s.43	72-hour notification per Section 6

3.1.2 Contractual Obligations

In addition to statutory obligations, M4E's contractual obligations under the Service Agreement include:

- Data ownership acknowledgement (Client owns all data)
- Data retention and deletion schedules
- Data export in specified formats upon termination
- Anomaly detection and reporting
- Transparent communication cost reporting
- Audit trail maintenance for all data modifications

3.2 Client as Data Controller

Each Client, as Data Controller, has the following compliance obligations:

3.2.1 Statutory Obligations (NDPA s.28-33)

Obligation	NDPA Reference	Implementation Guidance
Publish a privacy policy	s.28	Client must maintain a privacy policy covering M4E processing; M4E provides template guidance
Appoint a Data Protection Officer (where required)	s.29	Required for Controllers processing data of significant volume; Client to assess applicability
Maintain records of processing activities	s.30	Client must document all processing purposes, categories, recipients, transfers, and retention periods
Conduct DPIA for high-risk processing	s.31	DPIA template provided in Section 5 of this framework
Prior consultation with NDPC (where DPIA indicates high risk)	s.32	Client must consult NDPC before processing if DPIA indicates residual high risk
Notify NDPC of data breaches	s.33	Within 72 hours where breach poses risk to Data Subject rights; M4E assists per Section 6
Ensure lawful basis for processing	s.25	Client must identify and document lawful basis for each processing activity
Obtain valid consent (where applicable)	s.26	Client must obtain NDPA-compliant consent for marketing to new prospects
Honour Data Subject rights	s.34-40	Client must respond to rights requests; M4E provides technical assistance
Ensure data accuracy	s.24(1)(d)	Client responsible for accuracy of data uploaded to Platform

3.2.2 Recommended Client Actions

M4E recommends that each Client:

1. **Review and update** their own privacy policy to reference M4E as a Data Processor and describe the reactivation processing;
2. **Assess** whether a Data Protection Officer appointment is required based on the volume and nature of data processed;
3. **Document** the lawful basis for sharing customer data with M4E (legitimate interest for existing customers; consent for new prospects);
4. **Implement** consent collection mechanisms for new prospects before uploading their data to the Platform;

5. **Establish** internal procedures for handling Data Subject rights requests, with M4E as a technical support resource;
 6. **Conduct** or commission a Data Protection Impact Assessment using the template in Section 5;
 7. **Register** with the NDPC as a Data Controller if processing thresholds are met (see Section 8);
 8. **Engage** a licensed Data Protection Compliance Organisation (DPCO) for annual audit compliance (see Section 9).
-

4. LAWFUL BASIS ASSESSMENT FRAMEWORK

4.1 Overview

The NDPA (s.25) provides six lawful bases for processing personal data. M4E and its Clients must identify and document the applicable lawful basis for each processing activity before processing commences.

4.2 Lawful Basis Decision Matrix

The following decision matrix assists in identifying the appropriate lawful basis for common M4E Platform processing activities:

LAWFUL BASIS DECISION FLOWCHART

1. Does the Data Subject have a prior purchase history with the Client?
 - └ YES → Legitimate Interest (s.25(1)(f))
(subject to LIA – see Section 4.3)
 - └ NO → 2. Has the Data Subject given explicit consent for marketing communications?
 - └ YES → Consent (s.25(1)(a))
 - └ NO → DO NOT PROCESS for marketing purposes
3. Is the processing necessary for performing the Service Agreement?
 - └ YES → Contract Performance (s.25(1)(b))
 - └ NO → Assess other lawful bases
4. Is the processing required by Nigerian law?
 - └ YES → Legal Obligation (s.25(1)(c))
 - └ NO → Assess remaining lawful bases

4.3 Legitimate Interest Assessment (LIA) Template

Where Legitimate Interest is relied upon, the following three-part assessment must be documented:

Part 1: Purpose Test

Question	Assessment
What is the legitimate interest being pursued?	<i>[e.g., Re-engaging existing customers to drive repeat purchases and maintain the commercial relationship]</i>
Who benefits from the processing?	<i>[e.g., The Client (increased revenue), the End Customer (relevant offers and reminders), M4E (service delivery)]</i>
Is the interest recognised in law or industry practice?	<i>[e.g., Yes — customer retention and reactivation is a recognised commercial practice]</i>
Are there any public interest considerations?	<i>[e.g., No adverse public interest implications]</i>

Part 2: Necessity Test

Question	Assessment
Is the processing necessary for the stated purpose?	<i>[e.g., Yes — personalised reactivation requires processing of contact and transaction data]</i>
Could the purpose be achieved with less data or less intrusive means?	<i>[e.g., No — effective segmentation and personalisation require purchase history and contact details]</i>
Is the processing proportionate to the interest pursued?	<i>[e.g., Yes — only data necessary for reactivation is processed]</i>

Part 3: Balancing Test

Question	Assessment
What is the nature of the personal data?	<i>[e.g., Contact details and purchase history — not sensitive data]</i>
What are the reasonable expectations of the Data Subject?	<i>[e.g., Existing customers reasonably expect to receive communications from businesses they have purchased from]</i>
What is the likely impact on the Data Subject?	<i>[e.g., Minimal — receiving relevant marketing communications with easy opt-out]</i>
Is the Data Subject vulnerable?	<i>[e.g., No specific vulnerability identified]</i>
What safeguards are in place?	<i>[e.g., Opt-out mechanisms in all communications; data security measures; data minimisation; retention limits]</i>
Conclusion	<i>[e.g., The legitimate interest of the Client in re-engaging existing customers does not override the rights and freedoms of the Data Subjects, given the pre-existing commercial relationship, the non-sensitive nature of the data, the reasonable expectations of the Data Subjects, and the safeguards in place]</i>

4.4 Consent Requirements Checklist

Where consent is the applicable lawful basis, the following requirements must be met (NDPA s.26):

- ☐ Consent is **freely given** — not conditional on service provision where consent is not necessary
- ☐ Consent is **specific** — clearly identifies the processing purposes and channels (email, WhatsApp, SMS)

- ☐ Consent is **informed** — Data Subject is provided with clear information about the processing before consenting
- ☐ Consent is **unambiguous** — demonstrated by a clear affirmative action (opt-in, not pre-ticked boxes)
- ☐ Consent is **demonstrable** — the Client can evidence when and how consent was obtained
- ☐ Consent is **withdrawable** — Data Subject is informed of the right to withdraw and can do so easily
- ☐ Consent is **recorded** — timestamp, method, and scope of consent are documented
- ☐ Consent is **age-appropriate** — if Data Subjects may include minors, parental consent mechanisms are in place

5. DATA PROTECTION IMPACT ASSESSMENT (DPIA)

5.1 When a DPIA Is Required

Under NDPA s.31, a DPIA must be conducted before processing that is likely to result in a high risk to the rights and freedoms of Data Subjects. The following M4E Platform activities may trigger a DPIA requirement:

Activity	Risk Factor	DPIA Required?
Large-scale processing of customer databases (>10,000 records)	Volume of data	Likely yes
Automated segmentation and profiling of customers	Automated decision-making	Likely yes
Multi-channel marketing campaigns (email + WhatsApp + SMS)	Multiple processing purposes and channels	Assess on case-by-case basis
Cross-border data transfers to Sub-Processors	International transfers	Likely yes
Processing of customer purchase history for CLV calculation	Behavioural profiling	Assess on case-by-case basis

5.2 DPIA Template

The following template should be completed for each processing activity requiring a DPIA:

DATA PROTECTION IMPACT ASSESSMENT

Assessment Reference: DPIA-[CLIENT]-[YEAR]-[NUMBER]

Date of Assessment: ____

Assessor: ____

Reviewed By: ____

Section A: Processing Description

Item		Description
Nature of Processing	of	<i>[Describe what the processing involves — e.g., importing customer database, segmenting by purchase recency, executing multi-channel reactivation campaigns]</i>
Scope of Processing	of	<i>[Number of Data Subjects, categories of data, geographic scope, duration]</i>
Context of Processing	of	<i>[Relationship between Controller and Data Subjects, Data Subject expectations, prior experience with similar processing]</i>
Purpose of Processing	of	<i>[Specific purposes — e.g., customer reactivation, segmentation, campaign delivery, performance measurement]</i>
Lawful Basis		<i>[Identified lawful basis with justification — reference LIA if applicable]</i>
Data Flows		<i>[Describe how data moves: Client → M4E Platform → Sub-Processors → End Customers]</i>

Section B: Necessity and Proportionality Assessment

Question	Assessment
Is the processing necessary for the stated purpose?	
Could the purpose be achieved with less data?	
Is the processing proportionate to the purpose?	
How is data quality ensured?	
What is the data retention period and justification?	
How are Data Subject rights facilitated?	
What mechanisms exist for consent management (if applicable)?	

Section C: Risk Assessment

Risk	Likelihood (Low/ Medium/ High)	Severity (Low/ Medium/ High)	Overall Risk	Mitigation Measures
Unauthorised access to customer data				[e.g., RBAC, encryption, audit logging]
Data breach during transmission				[e.g., TLS 1.2+, API security]
Excessive data collection				[e.g., Data minimisation policy, field-level restrictions]
Inaccurate segmentation leading to inappropriate communications				[e.g., Data validation, anomaly detection]
Failure to honour opt-out requests				[e.g., Automated opt-out processing, compliance monitoring]
Sub-Processor data breach				[e.g., DPA with Sub-Processors, security due diligence]
Cross-border transfer without adequate safeguards				[e.g., SCCs, adequacy assessments, encryption]
Retention beyond necessary period				[e.g., Automated retention enforcement, deletion schedules]
Inability to respond to Data Subject requests				[e.g., Documented procedures, technical capabilities]

Section D: Consultation

Stakeholder	Consulted?	Input Received
Data Protection Officer (if appointed)		
IT/Security Team		
Legal Counsel		
Data Subjects (or representatives)		
NDPC (if residual high risk)		

Section E: Decision

Item	Response
Overall Risk Level (after mitigation)	☐ Low ☐ Medium ☐ High
Decision	☐ Proceed ☐ Proceed with conditions ☐ Do not proceed ☐ Consult NDPC
Conditions (if applicable)	
Review Date	

Signatures:

Role	Name	Signature	Date
Data Controller Representative			
Data Processor Representative (M4E)			
Data Protection Officer (if applicable)			

5.3 DPIA Review Schedule

DPIAs should be reviewed and updated:

- Annually, as part of the compliance audit cycle;
- When there is a significant change in processing activities;
- When new Sub-Processors are engaged;
- When new data categories are introduced;
- Following a data breach or security incident.

6. DATA BREACH RESPONSE PROCEDURE

6.1 Definition

A "personal data breach" means a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data processed through the Platform.

6.2 Breach Response Timeline

Phase	Timeframe	Actions
Phase 1: Detection	T+0 (breach detected)	Identify the breach; activate incident response team; begin containment
Phase 2: Containment	T+0 to T+4 hours	Isolate affected systems; prevent further data exposure; preserve evidence
Phase 3: Assessment	T+4 to T+24 hours	Determine scope, severity, and categories of data affected; identify affected Data Subjects; assess risk to rights and freedoms
Phase 4: Internal Notification	T+24 hours	Notify M4E management; notify Client (Data Controller)
Phase 5: Regulatory Notification	T+72 hours (maximum)	Client notifies NDPC (where breach poses risk to Data Subject rights); M4E assists with notification
Phase 6: Data Subject Notification	Without undue delay	Client notifies affected Data Subjects (where breach poses high risk); M4E assists with identification and communication
Phase 7: Remediation	T+72 hours onwards	Implement corrective measures; patch vulnerabilities; update security controls
Phase 8: Post-Incident Review	T+14 days	Conduct root cause analysis; document lessons learned; update procedures

6.3 Breach Notification Content

6.3.1 Notification to Client (from M4E)

M4E's breach notification to the Client shall include:

1. Description of the nature of the breach
2. Categories of personal data affected
3. Approximate number of Data Subjects affected
4. Approximate number of personal data records affected

5. Name and contact details of M4E's incident response lead
6. Description of likely consequences
7. Description of measures taken or proposed to address the breach
8. Description of measures taken or proposed to mitigate adverse effects

6.3.2 Notification to NDPC (from Client)

The Client's notification to the NDPC shall include (per NDPA s.33):

1. Nature of the personal data breach
2. Categories and approximate number of Data Subjects concerned
3. Categories and approximate number of personal data records concerned
4. Name and contact details of the Data Protection Officer or other contact point
5. Description of the likely consequences of the breach
6. Description of the measures taken or proposed to address the breach

6.3.3 Notification to Data Subjects (from Client)

Where required, the Client's notification to Data Subjects shall include:

1. Clear and plain language description of the breach
2. Name and contact details of the Data Protection Officer or other contact point
3. Description of the likely consequences
4. Description of the measures taken or proposed to address the breach
5. Recommendations for the Data Subject to mitigate potential adverse effects

6.4 Breach Severity Classification

Severity	Criteria	Notification Required
Critical	Sensitive data exposed; large number of Data Subjects affected; data publicly accessible; identity theft risk	NDPC + Data Subjects + Client
High	Personal data exposed to unauthorised parties; moderate number of Data Subjects; financial data involved	NDPC + Data Subjects + Client
Medium	Limited personal data exposed; small number of Data Subjects; data recovered quickly; low risk of harm	NDPC + Client (Data Subject notification assessed case-by-case)
Low	Encrypted data exposed; no actual access to personal data; contained within M4E systems; negligible risk	Client (NDPC notification assessed case-by-case)

6.5 Breach Register

M4E shall maintain a register of all personal data breaches, regardless of severity, including:

- Date and time of breach detection
- Date and time of breach occurrence (if different)
- Nature and scope of the breach
- Categories of data and Data Subjects affected
- Cause of the breach
- Containment and remediation actions taken
- Notifications issued (to whom, when, content)
- Outcome and lessons learned

7. DATA SUBJECT REQUEST HANDLING PROCEDURES

7.1 Request Types and Procedures

7.1.1 Right of Access (NDPA s.34)

Step	Action	Responsible Party	Timeframe
1	Receive and log access request	Client (or M4E if received directly)	Day 0
2	Verify identity of Data Subject	Client	Days 1-3
3	Instruct M4E to compile data (if needed)	Client	Days 3-5
4	M4E extracts relevant data from Platform	M4E	Days 5-15
5	Client reviews and provides data to Data Subject	Client	Days 15-30
Total			30 days

Data to be provided:

- Confirmation of processing
- Categories of personal data processed
- Purposes of processing
- Recipients or categories of recipients
- Retention periods
- Information about Data Subject rights
- Source of data (if not collected directly)
- Copy of personal data in commonly used electronic format

7.1.2 Right to Rectification (NDPA s.35)

Step	Action	Responsible Party	Timeframe
1	Receive rectification request with correct data	Client	Day 0
2	Verify identity and validity of request	Client	Days 1-3
3	Instruct M4E to update records	Client	Days 3-5
4	M4E updates records in Platform	M4E	Days 5-10
5	Confirm rectification to Data Subject	Client	Days 10-30

7.1.3 Right to Erasure (NDPA s.36)

Step	Action	Responsible Party	Timeframe
1	Receive erasure request	Client	Day 0
2	Verify identity; assess whether exemptions apply	Client	Days 1-5
3	Instruct M4E to delete records (if no exemption)	Client	Days 5-7
4	M4E deletes records from Platform and active systems	M4E	Days 7-15
5	M4E confirms deletion (including from backups within backup cycle)	M4E	Days 15-30
6	Confirm erasure to Data Subject	Client	Day 30

Exemptions to erasure (processing may continue where necessary for):

- Exercising the right of freedom of expression and information
- Compliance with a legal obligation
- Reasons of public interest in the area of public health
- Archiving purposes in the public interest, scientific or historical research, or statistical purposes
- Establishment, exercise, or defence of legal claims

7.1.4 Right to Data Portability (NDPA s.38)

Step	Action	Responsible Party	Timeframe
1	Receive portability request	Client	Day 0
2	Verify identity	Client	Days 1-3
3	Instruct M4E to export data	Client	Days 3-5
4	M4E exports data in structured, machine-readable format (CSV/JSON)	M4E	Days 5-20
5	Provide data to Data Subject or transmit to nominated controller	Client	Days 20-30

7.1.5 Right to Object to Direct Marketing (NDPA s.39)

Step	Action	Responsible Party	Timeframe
1	Receive objection (via unsubscribe link, STOP keyword, or direct request)	M4E Platform (automated) or Client	Day 0
2	Immediately cease marketing communications to the Data Subject	M4E Platform (automated)	Immediate (within 24 hours)
3	Update suppression list in Platform	M4E	Immediate
4	Confirm cessation to Data Subject	Client or M4E (automated)	Within 5 days

7.2 Request Logging

All Data Subject requests shall be logged with:

- Date received
 - Type of request
 - Identity of Data Subject
 - Verification method used
 - Actions taken
 - Date of response
 - Outcome
-

8. NITDA/NDPC REGISTRATION REQUIREMENTS

8.1 Overview

Under the NDPA (s.54–58), Data Controllers and Data Processors of "major importance" must register with the NDPC. The criteria for "major importance" are determined by the NDPC based on factors including:

- Volume of personal data processed
- Nature of personal data processed
- Purpose of processing
- Risk to Data Subject rights and freedoms

8.2 M4E Registration Status

Requirement	Status	Action Required
NDPC Registration as Data Processor	To be assessed based on NDPC criteria	M4E to register when NDPC registration portal is operational and criteria are published
Annual Filing	Required upon registration	Submit annual compliance report
Registration Fee	As determined by NDPC	Budget for annual registration fee

8.3 Client Registration Obligations

Clients should assess their own registration obligations based on:

Factor	Assessment Criteria
Volume	Processing personal data of more than 2,000 Data Subjects in a 12-month period (NDPR threshold)
Nature	Processing sensitive personal data or data of vulnerable persons
Purpose	Processing for direct marketing, profiling, or automated decision-making
Risk	Processing likely to result in high risk to Data Subject rights

8.4 Transitional Provisions

During the transition from NDPR to NDPA:

- Existing NITDA filings remain valid until NDPC establishes its own registration system
 - Data Controllers who filed audit reports with NITDA should maintain records for NDPC transition
 - M4E monitors NDPC announcements for registration portal availability and updated criteria
-

9. DATA PROTECTION COMPLIANCE ORGANISATION (DPCO) REQUIREMENTS

9.1 Overview

Under the NDPR Implementation Framework, Data Controllers processing personal data of more than 2,000 Data Subjects must engage a licensed Data Protection Compliance Organisation (DPCO) to conduct their annual Data Protection Audit.

9.2 DPCO Functions

A licensed DPCO performs the following functions:

1. **Data Protection Audit** — Comprehensive assessment of data processing activities, security measures, and compliance status
2. **Compliance Advisory** — Guidance on achieving and maintaining compliance with NDPR/NDPA
3. **Training** — Data protection awareness training for personnel
4. **DPIA Support** — Assistance with conducting Data Protection Impact Assessments
5. **Audit Report Filing** — Preparation and submission of the annual Data Protection Audit report to NDPC/NITDA

9.3 M4E DPCO Engagement

Item	Detail
DPCO Engagement	M4E shall engage a NITDA/NDPC-licensed DPCO for annual compliance audits
Audit Scope	All personal data processing activities through the Platform
Audit Frequency	Annually (within 6 months of the end of each calendar year)
Report Filing	DPCO files audit report with NDPC on behalf of M4E
Cost	M4E bears the cost of its own DPCO engagement

9.4 Client DPCO Obligations

Clients processing personal data of more than 2,000 Data Subjects should:

1. Engage their own licensed DPCO for annual audits
2. Include M4E Platform processing activities within the scope of their audit
3. Request M4E's cooperation in providing information for the Client's audit
4. File the annual audit report with NDPC through their DPCO

9.5 DPCO Selection Criteria

When selecting a DPCO, consider:

- ☐ Licensed by NITDA/NDPC
- ☐ Experience with technology/SaaS platforms
- ☐ Understanding of multi-channel marketing data processing
- ☐ Familiarity with cloud-based data processing and Sub-Processor arrangements
- ☐ Track record of successful audit report filings
- ☐ Competitive pricing and clear scope of engagement

10. CROSS-BORDER TRANSFER MECHANISMS

10.1 Overview

The M4E Platform utilises cloud-based Sub-Processors that may process personal data outside Nigeria. Under NDPA s.45–48, cross-border transfers of personal data are permitted only where adequate safeguards are in place.

10.2 Transfer Inventory

Data Flow	Origin	Destination	Sub-Processor	Data Categories	Transfer Mechanism
Database hosting	Nigeria	US/EU (Supabase cloud)	Supabase	All End Customer data	DPA + encryption + SOC 2
WhatsApp messaging	Nigeria	Global (Meta infrastructure)	Meta	Phone numbers, message content	Meta Data Processing Terms
Email/SMS delivery	Nigeria	EU (Brevo data centres)	Brevo	Email addresses, phone numbers, content	DPA + GDPR compliance
Application hosting	Nigeria	Global (Vercel Edge)	Vercel	Session data, API metadata	DPA + encryption + SOC 2

10.3 Transfer Safeguard Assessment

For each cross-border transfer, the following assessment must be documented:

Transfer Impact Assessment Template

Assessment Item	Evaluation
Destination jurisdiction	<i>[Country/region]</i>
Adequacy determination by NDPC?	<i>[Yes/No/Pending]</i>
Applicable data protection law in destination	<i>[e.g., GDPR, CCPA, none]</i>
Sub-Processor certifications	<i>[e.g., SOC 2 Type II, ISO 27001]</i>
Contractual safeguards in place	<i>[DPA, SCCs, binding corporate rules]</i>
Technical safeguards	<i>[Encryption at rest, encryption in transit, access controls]</i>
Government access risk	<i>[Assessment of surveillance laws in destination jurisdiction]</i>
Supplementary measures required	<i>[Additional safeguards if standard mechanisms are insufficient]</i>
Overall transfer risk	<i>[Low/Medium/High]</i>
Decision	<i>[Proceed/Proceed with conditions/Do not proceed]</i>

10.4 NDPA Transfer Requirements

Under NDPA s.45, personal data may be transferred outside Nigeria where:

(a) The NDPC has determined that the destination jurisdiction ensures an adequate level of protection; or

(b) Appropriate safeguards are provided, including:

- Binding corporate rules approved by the NDPC
- Standard contractual clauses approved by the NDPC
- An approved code of conduct or certification mechanism
- Contractual clauses between the Controller/Processor and the recipient authorised by the NDPC

(c) The transfer is necessary for:

- The performance of a contract between the Data Subject and the Controller
- Important reasons of public interest
- The establishment, exercise, or defence of legal claims
- The protection of vital interests of the Data Subject

(d) The Data Subject has explicitly consented to the transfer after being informed of the risks.

10.5 M4E Transfer Compliance Measures

M4E implements the following measures for all cross-border transfers:

1. **Data Processing Agreements** with all Sub-Processors incorporating NDPA-equivalent data protection obligations
 2. **Encryption** of all data in transit (TLS 1.2+) and at rest (AES-256)
 3. **Access controls** limiting Sub-Processor access to the minimum necessary
 4. **Regular review** of Sub-Processor compliance and security certifications
 5. **Transfer impact assessments** for each Sub-Processor relationship
 6. **Monitoring** of regulatory developments regarding adequacy determinations and transfer mechanisms
-

11. ANNUAL AUDIT REQUIREMENTS

11.1 NDPR Audit Obligation

Under NDPR Art. 4.1, any Nigerian entity that processes personal data of more than 2,000 Data Subjects within a period of twelve (12) months must submit a Data Protection Audit report to NITDA (now NDPC) not later than 15 March of the following year.

11.2 Audit Scope

The annual Data Protection Audit should cover:

Audit Area	Scope
Data Inventory	Complete inventory of personal data processed, categories, volumes, and flows
Lawful Basis	Verification that a valid lawful basis exists for each processing activity
Consent Management	Assessment of consent collection, recording, and withdrawal mechanisms
Data Subject Rights	Review of procedures and response times for rights requests
Security Measures	Technical and organisational security assessment
Data Breach Management	Review of breach detection, response, and notification procedures
Sub-Processor Management	Assessment of Sub-Processor agreements and compliance
Cross-Border Transfers	Review of transfer mechanisms and safeguards
Data Retention	Verification of retention schedules and deletion procedures
Privacy Policies	Review of privacy notices for completeness and accuracy
Training	Assessment of data protection training programmes
DPIA	Review of DPIA processes and completed assessments

11.3 Audit Timeline

Activity	Deadline
Engage DPCO for annual audit	By 30 September of the audit year
Complete audit fieldwork	By 31 December of the audit year
Finalise audit report	By 28 February of the following year
Submit audit report to NDPC	By 15 March of the following year
Implement audit recommendations	Within 90 days of report finalisation

11.4 M4E Audit Cooperation

M4E shall cooperate with Client audits and DPCO engagements by:

1. Providing access to relevant Platform documentation and security information
2. Responding to audit questionnaires within ten (10) business days

3. Facilitating technical assessments of Platform security measures
4. Providing evidence of Sub-Processor compliance
5. Making relevant personnel available for audit interviews

12. RECORD-KEEPING OBLIGATIONS

12.1 Records of Processing Activities (ROPA)

Under NDPA s.30 (Data Controllers) and s.42 (Data Processors), both M4E and its Clients must maintain records of processing activities.

12.1.1 M4E Records (as Data Processor)

M4E shall maintain the following records:

Record	Content
Processor Identity	Name and contact details of M4E and each Client (Controller)
Processing Categories	Categories of processing carried out on behalf of each Client
International Transfers	Details of cross-border transfers, including destination jurisdictions and safeguards
Security Measures	Description of technical and organisational security measures
Sub-Processor Register	List of Sub-Processors with processing details and DPA status
Breach Register	Record of all personal data breaches
Data Subject Request Log	Record of all Data Subject requests received and actions taken
DPIA Register	Record of all DPIAs conducted
Consent Records	Records of consent obtained (where M4E collects consent directly)
Retention Schedule	Documentation of data retention periods and deletion actions

12.1.2 Client Records (as Data Controller)

Clients should maintain the following records (M4E can assist with Platform-related records):

Record	Content
Controller Identity	Name and contact details of the Client and any joint controllers
Processing Purposes	Purposes of each processing activity
Data Categories	Categories of personal data processed
Data Subject Categories	Categories of Data Subjects
Recipient Categories	Categories of recipients, including M4E as Processor
International Transfers	Details of cross-border transfers
Retention Periods	Envisaged time limits for erasure of different data categories
Security Measures	Description of technical and organisational security measures
Lawful Basis Documentation	Documentation of lawful basis for each processing activity
Consent Records	Records of consent obtained from Data Subjects
DPIA Records	Completed DPIAs and review records

12.2 Record Retention

Records of processing activities shall be retained for:

- Duration of the Service Agreement; plus
- Three (3) years after termination (to cover potential regulatory enquiries and limitation periods)

12.3 Record Format

Records shall be maintained in written form (including electronic form) and made available to the NDPC upon request.

13. PENALTIES AND ENFORCEMENT

13.1 NDPA Penalties

The NDPA provides for the following enforcement measures and penalties:

Violation	Penalty	NDPA Reference
Failure to comply with data processing principles	Administrative fine of up to ₦10,000,000 or 2% of annual gross revenue (whichever is greater)	s.59(2)(a)
Failure to comply with Data Subject rights	Administrative fine of up to ₦10,000,000 or 2% of annual gross revenue	s.59(2)(a)
Failure to comply with transfer provisions	Administrative fine of up to ₦10,000,000 or 2% of annual gross revenue	s.59(2)(a)
Serious violations (e.g., processing without lawful basis, failure to notify breach)	Administrative fine of up to ₦20,000,000 or 4% of annual gross revenue (whichever is greater)	s.59(2)(b)
Obstruction of NDPC investigation	Criminal penalty: fine and/or imprisonment	s.62
Unlawful obtaining or disclosure of personal data	Criminal penalty: fine and/or imprisonment up to 3 years	s.63
Selling unlawfully obtained personal data	Criminal penalty: fine and/or imprisonment up to 5 years	s.64

13.2 NDPR Penalties (Transitional)

Until fully superseded by NDPC enforcement:

Violation	Penalty
Data Controller processing >10,000 Data Subjects	Fine of 2% of annual gross revenue or ₦10,000,000 (whichever is greater)
Data Controller processing <10,000 Data Subjects	Fine of 1% of annual gross revenue or ₦2,000,000 (whichever is greater)

13.3 NDPC Enforcement Powers

The NDPC has the following enforcement powers under the NDPA:

1. **Investigation** — Power to investigate complaints and conduct compliance audits
2. **Compliance Orders** — Power to order Controllers/Processors to comply with specific requirements
3. **Processing Bans** — Power to impose temporary or permanent bans on processing
4. **Administrative Fines** — Power to impose fines as specified in Section 13.1

- 5. **Criminal Referral** — Power to refer serious violations for criminal prosecution
- 6. **Public Warnings** — Power to issue public warnings and reprimands

13.4 Risk Mitigation

M4E mitigates regulatory risk through:

- 1. Comprehensive compliance framework (this document)
 - 2. Documented processing activities and lawful basis assessments
 - 3. Robust security measures exceeding minimum requirements
 - 4. Proactive breach detection and response procedures
 - 5. Regular compliance audits and DPCO engagement
 - 6. Ongoing monitoring of regulatory developments
 - 7. Staff training and awareness programmes
 - 8. Contractual protections in Service Agreements and Sub-Processor agreements
-

14. COMPLIANCE CHECKLIST

14.1 M4E Compliance Checklist (Data Processor)

#	Requirement	Status	Evidence	Review Date
1	Data Processing Agreement with each Client	☐ Complete	Service Agreement Section 8	
2	Processing only on documented instructions Controller	☐ Complete	Service Agreement; processing logs	
3	Confidentiality obligations for all personnel	☐ Complete	Employment contracts; NDAs	
4	Technical security measures implemented	☐ Complete	Security documentation; penetration test reports	
5	Organisational security measures implemented	☐ Complete	Policies; training records	
6	Sub-Processor agreements in place	☐ Complete	DPA's with Supabase, Meta, Brevo, Vercel	
7	Sub-Processor notification process established	☐ Complete	Client notification procedure	
8	Data Subject rights assistance procedures	☐ Complete	Section 7 of this framework	
9	Breach notification procedures	☐ Complete	Section 6 of this framework	
10	Breach register maintained	☐ Complete	Breach register document	
11	Records of processing activities maintained	☐ Complete	ROPA document	
12	Data retention schedules implemented	☐ Complete	Privacy Policy Section 8; automated enforcement	
13	Data deletion procedures established	☐ Complete	Service Agreement Section 8.7	
14	Cross-border transfer safeguards in place	☐ Complete	Transfer impact assessments; DPA's	
15	DPIA support capability established	☐ Complete	Section 5 of this framework	
16	Privacy Policy published	☐ Complete	M4E-PP-2025-001	
17	DPCO engaged for annual audit	☐ Pending	To be engaged	

#	Requirement	Status	Evidence	Review Date
18	NDPC registration (when portal available)	☐ Pending	Monitoring announcements NDPC	
19	Staff data protection training completed	☐ Complete	Training records	
20	Compliance framework documented	☐ Complete	This document (M4E-NDPR-CF-2025-001)	

14.2 Client Compliance Checklist (Data Controller)

#	Requirement	Status	Action Required
1	Privacy policy published and covers M4E processing	☐	Update privacy policy to reference M4E as Data Processor
2	Lawful basis identified and documented for each processing activity	☐	Complete lawful basis assessment using Section 4 framework
3	Consent obtained for marketing to new prospects (where applicable)	☐	Implement consent collection mechanisms
4	Data Subject rights procedures established	☐	Establish internal procedures; coordinate with M4E
5	Data Protection Officer appointed (if required)	☐	Assess whether DPO appointment is required
6	Records of processing activities maintained	☐	Create and maintain ROPA
7	DPIA conducted for high-risk processing	☐	Complete DPIA using Section 5 template
8	Breach notification procedures established	☐	Establish internal breach response procedures
9	NDPC registration completed (if required)	☐	Assess registration obligation; register when portal available
10	DPCO engaged for annual audit (if required)	☐	Engage licensed DPCO
11	Annual audit report filed with NDPC	☐	File by 15 March of the following year
12	Staff data protection training completed	☐	Conduct training for staff handling personal data
13	Data accuracy procedures in place	☐	Implement data quality checks before uploading to Platform
14	Data retention aligned with Service Agreement	☐	Review and confirm retention periods
15	Cross-border transfer awareness	☐	Acknowledge and accept Sub-Processor transfer arrangements

15. REFERENCES

15.1 Primary Legislation and Regulations

Reference	Full Title	Date	Authority
NDPA 2023	Nigeria Data Protection Act 2023	12 June 2023	Federal Republic of Nigeria
NDPR 2019	Nigeria Data Protection Regulation 2019	25 January 2019	NITDA
NDPR IF 2020	NDPR Implementation Framework	November 2020	NITDA
NITDA Act 2007	National Information Technology Development Agency Act 2007	2007	Federal Republic of Nigeria

15.2 Related M4E Documents

Document	Document ID	Description
Database Reactivation Service Agreement	M4E-DBRA-2025-001	Service agreement including Data Processing Agreement (Section 8)
Privacy Policy	M4E-PP-2025-001	Platform privacy policy
NDPR/NDPA Compliance Framework	M4E-NDPR-CF-2025-001	This document

15.3 Regulatory Bodies

Body	Role	Website
Nigeria Data Protection Commission (NDPC)	Primary data protection supervisory authority (established under NDPA 2023)	https://ndpc.gov.ng
National Information Technology Development Agency (NITDA)	Original issuing authority for NDPR 2019; technology development agency	https://nitda.gov.ng

15.4 International Standards Referenced

Standard	Relevance
GDPR (EU)	Referenced for cross-border transfer mechanisms and best practice alignment
ISO 27001	Information security management system standard
SOC 2 Type II	Service organisation control standard (Sub-Processor compliance)

16. DOCUMENT CONTROL

16.1 Version History

Version	Date	Author	Description
1.0	June 2025	Marketing4Effect	Initial publication

16.2 Review Schedule

This framework shall be reviewed and updated:

Trigger	Frequency
Scheduled review	Annually (by 31 March)
Regulatory change	Within 90 days of new legislation, regulation, or NDPC guidance
Significant processing change	Before new processing commences
Data breach	Within 30 days of post-incident review
Sub-Processor change	Before engaging new Sub-Processor
Audit finding	Within 90 days of audit report

16.3 Approval

Role	Name	Signature	Date
M4E Management			
Data Protection Lead			
Legal Counsel (if applicable)			

16.4 Distribution

This document is classified as **Internal — Confidential** and is distributed to:

- M4E management and personnel involved in data processing
 - Clients (upon request or as part of onboarding)
 - DPCO (for audit purposes)
 - NDPC (upon regulatory request)
-

This compliance framework is published by Marketing4Effect (M4E) and provides operational guidance for compliance with the Nigeria Data Protection Regulation (NDPR) 2019 and the Nigeria Data Protection Act (NDPA) 2023 in relation to the M4E Customer Reactivation Manager platform.

Document Version: 1.0

Last Updated: June 2025

Document ID: M4E-NDPR-CF-2025-001